

「安智盾」

面向政企大模型智能体的安全防护与审计溯源关键技术研究

技术方案报告

系统名称：安智盾（策略引擎 + OpenClaw 插件 gov-agent-guard）

版本：策略引擎 / 插件 2.5.1

核心原则：策略判定与工具执行分离；白名单可配置；样本代码不落地执行

一、项目简介

本项目面向政务办公、知识检索、业务办理和智能运维等政企智能体应用场景，构建集“攻击识别、工具管控、组件检测、审计溯源”于一体的安全防护体系。系统针对提示注入、越狱诱导、知识投毒、插件与 Skill 供应链风险以及高危工具调用等问题，将安全控制从模型侧约束延伸至策略决策、工具调用、组件安装和运行审计全过程。

项目采用“离线评测引擎 + 在线策略决策点（PDP）”架构。离线侧用于量化防护效果、复现攻击样本并验证策略；在线侧通过 OpenClaw 原生插件，在工具真正执行前完成允许、阻断或人工审批判定，并沉淀运行时审计证据。策略引擎只负责安全判定，不执行命令、不访问外网、不打开浏览器，由宿主负责具体工具执行。

能力方向	系统落地
攻击识别	五维 IFC 评测 + 运行时白名单，对提示注入、越狱诱导、越权工具调用、来文投毒等风险进行识别与拦截
工具管控	场景工具白名单 + 文件 / 命令 / 浏览器 / 接口执行门禁 + HITL 动态审批
组件检测	插件 / Skill / 脚本供应链静态扫描，安装前门禁且不执行样本代码
审计溯源	runtime_audit、评测审计、/guard 会话证据链、JSON/Markdown 导出与审批落盘

二、作品定位与核心安全问题

政企智能体在具备工具调用和任务执行能力后，安全边界由“模型输出是否合理”进一步扩展到“模型能调用什么、组件能否进入环境、高危操作能否真正执行以及事后能否追溯”。本项目聚焦三类核心风险：

- 插件与 Skill 供应链投毒：组件可能携带后门、恶意下载、隐蔽外联或依赖混淆等风险。
- 提示注入与越权工具调用：外部输入可能诱导智能体突破既定任务边界，调用不应使用的工具。
- 高危执行动作失控：文件删除、命令执行、接口调用等行为若缺乏运行时门禁，模型输出可能直接转化为实际风险。

针对上述问题，安智盾不将安全责任单纯寄托于模型“自觉遵守提示词”，而是将高风险行为的最终控制点放在独立策略决策层，使智能体的工具调用必须经过安全策略判定后才能进入执行环节。

三、技术创新点与方案优势

本项目的创新重点不在于重新构建一个大模型，而在于将政企智能体安全建设为“可配置、可评测、可嵌入运行时、可审批、可追溯”的工程体系。

3.1 策略白名单网关：从“提示词约束”走向“执行权限约束”

传统智能体安全往往依赖系统提示词、模型自检或事后日志，对模型最终是否调用高风险工具缺少独立控制点。安智盾将高危动作的允许条件固化到 `policies/*.yaml / json` 中，通过收件域、路径前缀、命令二进制、域名和场景工具清单等规则进行策略判定。

- 判定可审计、可复现；策略可 Diff、可版本管理。
- 与模型解耦：模型可以提出工具调用意图，但最终执行权限由策略层决定。

3.2 “评测—优化—上线”闭环：让安全效果可量化、可复算

项目将攻击面划分为数据、内容、执行、供应链（来文）和合规五个维度，分别计算 Baseline ASR、防护后 ASR 和 FPR，并支持单样本复现、策略修改后的 `--rescore` 重算以及指标历史记录。

- 形成“发现问题→修改策略→验证效果→重新上线”的持续迭代闭环。
- 使攻击识别从经验判断转变为可量化、可迭代的工程过程。

3.3 安装期与运行期“双门禁”：覆盖供应链入口与运行过程

项目将恶意组件与外部来文诱导越权进行语义分层，分别覆盖安装期静态扫描、办理流多维评测以及 OpenClaw 安装/工具调用钩子。

- 安装前检测组件风险，运行时约束工具权限。
- 静态检测不执行样本代码，降低评测过程本身的风险。

3.4 执行链对象化门禁 + HITL：兼顾“能办”与“可控”

针对文件、命令、浏览器和接口等高风险工具，将智能体属性、任务属性、工具属性及限制策略纳入统一执行链判定；限制策略采用 `puncture (deny-overrides)` 语义，任务对象头采用独立密钥 HMAC-SHA256。

- 高风险写、删以及疑似安装行为可进入人工审批。
- ALLOW、BLOCK、PENDING_APPROVAL 分别对应放行、阻断和人工确认。

3.5 原生嵌入 OpenClaw：审批与审计进入智能体 workflow

通过 `before_tool_call` 和 `before_install` 原生钩子接入安全策略层，不另建与业务对话割裂的独立安全控制台。

- /guard 查询最近判定、待审批列表和会话证据链。
- 审批结果、allow-always 指纹及运行时审计可持久化。

3.6 场景化最小权限：从“一套规则”转向“按业务配置权限”

内置 office、knowledge、process、ops 四类场景，路径、命令、域名、邮箱域和工具列表均可配置，可按单位资产台账填充，无需修改核心引擎代码。

- 避免全局权限过松或过紧。
- 支持不同岗位、业务和安全边界的差异化配置。

3.7 强制鉴权与运维配套：增强实际试点能力

策略 API 默认强制 Bearer 鉴权；插件 token 与引擎保持一致；缺 token 时钩子路径默认阻断，并提供令牌同步与初始化脚本。

- 策略口有明确身份边界。
- failClosed 与运维引导使安全控制更适合按验收清单进行试点。

四、总体架构与数据流

系统由离线评测引擎、在线策略决策点（PDP）、OpenClaw 插件和审计证据链构成。四大安全能力最终在统一 PDP 汇合：攻击识别提供风险判断，工具管控负责执行门禁，组件检测负责安装前安全检查，审计溯源记录策略与审批全过程。

模块	主要职责
供应链静态检测	扫描解包目录行为、依赖与恶意模式并评级
五维 IFC 网关	工具参数白名单、信任等级与 HITL
五维评测	ASR/FPR、攻击复现、策略重算与历史记录
执行门禁	文件、命令、浏览器、API 门禁与 HMAC 对象头
运行时 PDP	场景路由、三引擎汇合、审批持久化与审计
证据链	/guard 会话链、文本卡片、JSON/Markdown 导出
OpenClaw 插件	工具前钩子、安装前钩子、审批回写、/guard
运维引导	令牌与密钥初始化、插件同步

五、运行时安全判定机制

- 1. 规范化工具名称及参数别名，例如 exec→run_command、write→write_file。
- 2. 检查当前场景 allow 表，不在允许范围内的调用直接阻断。
- 3. 检查 allow-always 或当前会话已批准指纹，命中后放行。
- 4. 根据工具类型分流至 IFC、执行门禁或供应链扫描。
- 5. 统一输出 ALLOW、BLOCK 或 PENDING_APPROVAL。
- 6. 将判定写入 runtime_audit，并保存待审与 allow-always 状态。
- 7. 通过 OpenClaw hook 返回执行、阻断或审批结果。

结果	宿主表现	含义
ALLOW	继续执行	策略通过
BLOCK	工具不执行并返回原因	场景禁止或硬规则失败
PENDING_APPROVAL	进入审批流程	规则允许但需人工确认

六、四大安全能力实现

6.1 攻击识别：五维 IFC 评测与运行时白名单

维度	典型关注风险
数据安全	越权查库、导出敏感字段
内容安全	提示注入诱导违规外发 / 摘要
执行安全	危险命令、越权写删
供应链（来文）	伪造发件域、恶意链接进入办理
合规	审批缺失、越权场景工具

网关通过参数和来源标签白名单进行约束，并支持 HITL。mock 模式可在无大模型密钥条件下完成演示，api 模式可接 OpenAI 兼容 Function Calling。

6.2 工具管控：统一执行门禁与人工审批

系统覆盖文件、命令、浏览器和 API 等工具类型，围绕智能体属性与资源属性建立权限关系。高风险写、删等行为可配置 approval: true，进入待审状态而非静默执行。评测过程不真实执行样本任务。

6.3 组件检测：插件 / Skill / 脚本供应链静态扫描

扫描对象为已解包本地目录，绝不执行样本脚本或安装逻辑。系统输出 ALLOW / REVIEW / BLOCK，并附评分、发现项和问题定位；规则权重、危险 API / 模式、依赖混淆启发式和阻断阈值均可配置。

6.4 审计溯源：运行时证据链与审批持久化

系统记录运行时逐次策略判定、待审批状态和 allow-always 指纹，并通过 /guard 提供最近判定、待审列表以及按会话 ID 组织的时间顺序证据链；/guard export 可导出 JSON 与 Markdown。

七、OpenClaw 接入与安全加固

- before_tool_call：每次工具调用前询问策略引擎；无 config.token 时直接阻断。
- before_install：安装前进行供应链扫描；硬风险直接阻断，疑似风险进入审批。
- /guard：查询最近判定、待审列表和会话时间顺序证据链。
- /guard export：导出 JSON 与 Markdown 证据。
- POLICY_TOKEN：/v1/policy/* 默认强制 Bearer 鉴权。
- failClosed：策略引擎不可达时默认阻断工具。
- HMAC 对象头：使用独立密钥，并绑定 kid、iat、会话与工具信息。
- 审计轮转：默认保留最近约 2000 条运行时记录。

八、使用与比赛验证

策略引擎默认运行于 http://127.0.0.1:18210，可通过 GET /api/health 进行健康检查。比赛演示建议按照“供应链静态检测→多维评测→执行门禁→OpenClaw 在线演示→证据链查询”的顺序组织。

环节	展示内容	突出优势
多维评测	mock、单样本复现、--rescore	安全效果可量化、可复算
供应链检测	静态扫描与风险分级	安装前门禁、样本不执行
执行门禁	属性树、限制策略、审批任务	高危操作可控
OpenClaw	office 下 shell 阻断；ops 下 write 待审	策略真正嵌入运行时
审计溯源	/guard、/guard export	审批与证据链可追溯
策略配置	scenarios.json 等	可按单位资产台账定制

九、主要 API 与输出证据

用途	接口 / 输出
健康检查	GET /api/health
通用策略检查	POST /v1/policy/check
OpenClaw 工具前钩子	POST /v1/policy/openclaw/before-tool-call
OpenClaw 安装前钩子	POST /v1/policy/openclaw/before-install
审批回写	POST /v1/policy/approvals/{id}
证据链	GET /v1/policy/trace?q=
证据导出	GET /v1/policy/export?q=&format=both
场景列表	GET /v1/policy/scenarios
运行时审计	outputs/runtime_audit.jsonl
待审状态	outputs/runtime_pending.json
指标历史	outputs/metrics_history.json

十、项目综合优势

优势维度	具体体现
安全控制前移	在工具真正执行前进行策略判定，而非仅依赖事后审计
能力覆盖完整	攻击识别、工具管控、组件检测、审计溯源四线协同
策略工程化	白名单可配置、可审计、可复现、可 Diff、可版本管理
效果可量化	五维 ASR/FPR 独立核算，支持复现、重算和历史记录
供应链可控	安装期静态检测与运行期策略控制形成双门禁
风险分级处置	支持 BLOCK 与 HITL，不以“一律禁止”牺牲业务能力
原生宿主集成	直接接入 OpenClaw 工具调用与安装流程
审计可追溯	运行时判定、审批状态和会话证据链持久化
部署可适配	场景化最小权限，可按单位资产台账配置
运维有保障	策略接口强制鉴权、token 同步与 failClosed 机制

十一、项目边界与诚实说明

- TCA 密码学：当前运行时采用独立密钥的 HMAC-SHA256 对象头，包含 kid / iat / 业务绑定；Charm/ABE 实验实现未接入当前 PDP。
- 策略引擎不执行工具：系统遵循“先问后做”，未经过 OpenClaw 指定钩子的调用通道不属于本系统防护范围。
- 钩子覆盖存在边界：缺少插件 token 会阻断钩子路径，但未安装插件、其他宿主或直连执行仍需要运维侧保证高危能力统一经过安全插件。
- 安装待审依赖宿主：before_install 已返回 requireApproval；若客户端未实现对应 UI，需要在 Control 侧确认；硬拦截仍直接拒绝安装。
- 三套评测语料与在线 Agent 循环仍相对独立，完整串联按使用文档组织。
- 宿主工具集决定可演示能力；缺少对应工具时，可使用 HTTP 自测或已有工具完成相应能力展示。

十二、比赛答辩建议

答辩建议围绕“不是靠提示词、不是事后审计，而是先问后做、先审后装、全程留痕”展开。

- 一句话定位：“安智盾是一套可配置白名单 PDP，结合五维量化评测与 OpenClaw 原生审批溯源的政企智能体安全体系。”
- 展示五维评测，说明安全效果能够量化、复现和重算。
- 展示供应链静态检测，强调安装前门禁以及样本不执行。
- 展示 office 场景下 shell 阻断和 ops 场景下 write 待审，证明策略真正作用于工具执行前。
- 通过 /guard 展示会话证据链，再打开策略文件说明规则能够按单位资产台账填充。

建议收尾强调：安智盾不是增加一个孤立的安全检测模块，而是把安全策略真正嵌入智能体的“感知—决策—调用—执行”链路，使安全规则能够被配置、被评测、被执行、被审批、被追溯。

十三、目录速查

目录	作用
policies/	全部可配置策略，白名单核心
test_docs/	五维对照样本
supply_chain_samples/	供应链对照包
execution_samples/	执行门禁对照任务
src/engine/	供应链、IFC、执行门禁、TCA、运行时、溯源

plugins/gov-agent-guard/	OpenClaw 插件 (2.5.1)
scripts/	ops_bootstrap、ops_sync_token 等运维脚本
outputs/	评测与运行时审计、令牌与导出
docs/	使用文档与作品说明书

结语

安智盾将政企大模型智能体安全从“模型侧提示词约束”推进到“可配置策略网关 + 可量化五维评测 + 可嵌入宿主的审批与证据链 + 可落地的鉴权与运维配套”。攻击识别、工具管控、组件检测和审计溯源四条能力在统一 PDP 上汇合，实现白名单可配置、评测可复现可重算、运行时先问后做、安装先审后装，为高风险政企业务中的智能体应用提供更加明确、可控和可追溯的安全边界。